

Toward a science of cybersecurity

Question: Will cybersecurity ever become a science?

- Is it necessary? What are the drivers that would make it so?
- What would such a shift change in terms of our approach to it, in both academia, and in the professional workforce?

Position: The transition of cybersecurity from a professional craft toward an engineering science is already underway today.

- Traditional craft skills are no longer sufficient in a modern context
- As AI continues to be adopted as a force multiplier for practitioners in this space, engineering disciplines are required to build reliable and predictable systems.



A Historical Precedent: The Transition of Alchemy to Chemistry

01



The craft: Alchemy

- Localized craft (often perceived as “magic”)
- Based on practitioner’s intuition, secret recipes, and unique touches

02



Limits of the craft → the need for change

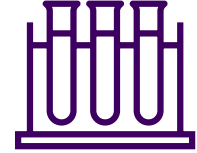
No reproducibility: methods were secret; no collective body of knowledge

No falsifiability: No formal method to prove hypothesis. Blame the “spirits”.

No systemic observation: Based on scents, looks, and vibes rather than empirical data.

No formal theory: Only rules of thumb.

03



Chemistry

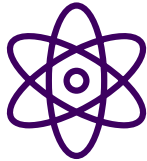
- Universal Science, based on verifiable laws
- Employs standardized methodology, open literature, and reproducible experiments

Alchemy, in its craft form, could not reliably be used to take on the role of modern medicine. It was missing what we know today as the four pillars of the Scientific Method.

The Case for Cybersecurity as an engineering science

Natural Science (e.g. Chemistry, Astronomy, Biology)

- **Descriptive Objective:** Focus on *describing* immutable, natural laws and behaviours.
- **Discovery-Oriented:** Knowledge is *sought* by uncovering pre-existing phenomena.
- **Experimental Falsifiability:** Theories are tested against nature. If an observation contradicts a theory, it is discarded or revised.
- **Inherent Universality:** The laws of a natural science are constant across time and space.



Engineering Science: (Aerospace, Software, Civil)

- **Prescriptive Objective:** Focus on *defining* how an artifact should behave to perform a function
- **Design-Oriented:** Knowledge is *built* by creating new artifacts and measuring their effectiveness
- **Axiomatic Logic:** Systems are built on human-defined axioms (like Zero Trust) rather than natural laws.
- **Purposeful Utility:** Every pursuit is tied to a specific end-use or problem-solving outcome



The Present-Day Challenge: The Increasing Velocity and Volume

29 mins

average breakout time in
2025, down from 98
minutes in 2021

CrowdStrike, 2026

27 secs

fastest recorded breakout
time in 2025

CrowdStrike, 2026

2,973

average daily alerts per
SOC analyst

Vectra AI, 2026

38%

percentage of alerts
analysts are able to
address

Vectra AI, 2026

Cybersecurity has reached its capacity as a human-led craft.

We do not just want a science of cybersecurity. ***We require one.***

Threat Detection – From Human Craft to Engineering Science



Craft-era Threat Detection

- **Intuition-Driven Triage:** Decision-making relies on the analyst's personal experience and gut feel to determine which alerts are meaningful.
- **Heroic Manual Response:** Success is dependent on the speed and skill of a human operator manually executing remediation steps.
- **Anecdotal Knowledge:** Lessons learned are often localized to a specific team or shift, existing as unwritten "rules of thumb" rather than shared theory.
- **No Formal Verification:** Controls are assumed to work until they visibly fail, with no systematic method to test or prove effectiveness



Engineering-era Threat Detection

- **Deterministic Logic:** Triage is governed by formal design claims and if/then logic that ensures consistent outcomes regardless of the analyst.
- **Codified Automation:** Response actions are executed via auditable, workflows that have been formally specified and tested.
- **Systematic Observation:** Operations rely on clean, normalized telemetry, providing a structured data pipeline for continuous analysis.
- **Formal Verification:** The effectiveness of a control is treated as a testable hypothesis; success is proven through rigorous measurement against defined security axioms.

Vulnerability Management – From Patching to CTEM



Craft-era Vulnerability Management

- **Periodic Scanning:** Relies on scheduled cycles (quarterly or monthly)
- **Ordinal Prioritization:** Ranks threats using generic CVSS severity scores, ignoring specific business context
- **Human-Linear Remediation:** Success depends on a list of CVEs worked through manually by analysts
- **Assumed Remediation:** The process often ends once a patch is deployed, without automated, validated evidence that the exposure has been successfully neutralized.



Engineering-era Vulnerability Management (CTEM)

- **Real-Time Mapping:** Replaces snapshots with a continuous, automated loop that identifies changes in the attack surface as they occur.
- **Contextual Logic:** Prioritizes exposures by synthesizing asset inventories with external threat intelligence to identify actual vulnerabilities.
- **Codified Prioritization:** Moves from subjective analyst choice to codified prioritization logic.
- **Formal Validation:** Requires that every remediation action is mathematically or operationally verified, ensuring that the defensive design claim holds true against reality.

Compliance Management – From Reporting to Continuous Assurance



Craft-era Compliance Management

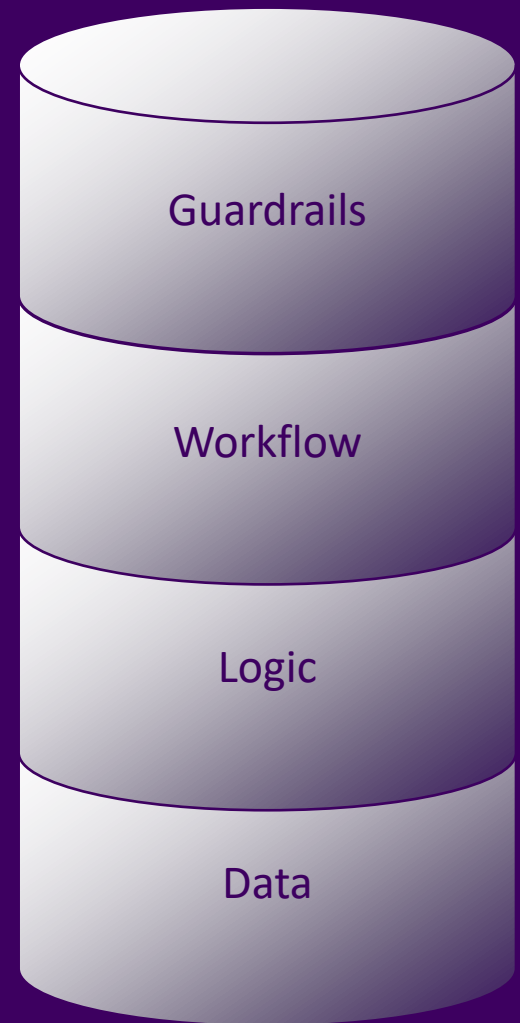
- **Periodic Attestation:** Relies on quarterly or annual audits, creating a point-in-time illusion of security that ignores control decay.
- **Administrative Exercise:** Treated as a bureaucratic ritual rather than a technical engineering requirement.
- **Human-Dependent Memory:** Success depends on a human remembering to configure a specific setting.
- **Reactive Posture:** Focuses on proving that controls were in place in the past, rather than ensuring they are actively remediated all the time.



Engineering-era Continuous Compliance Assurance

- **Axiomatic Encoding:** Encodes compliance requirements as formal axioms in the system architecture, making it difficult for a system to deviate from its intended state.
- **Automated Evidence Collection:** Replaces manual snapshots with a continuous data pipeline.
- **Governance-By-Design:** Integrates cybersecurity risk management into the broader enterprise engineering strategy.
- **Deterministic Resilience:** Ensures that compliance is a byproduct of the system's design.

*Defined **guardrails** and interlocks governing...*
*Codified **workflows** being executed by...*
*Deterministic or auditable probabilistic **logic**...*
*informed by clean, normalized, structured **data**.*



The Human Role – From Cyber Security Analyst to CyberAI Engineer



Craft-era Cyber Security Analyst

- **Triage Operator:** Analysts spend their shift manually reviewing high-volume alerts to distinguish true positives from noise.
- **Reliance on Craft Skills:** Investigation leverages personal experience and tribal knowledge, to prioritize tasks during peak alert periods.
- **Manual Remediation:** Response actions are executed through disparate tools, with the human acting as a bridge between them.
- **Vocational Focus:** Success is measured by the number of tickets closed, often leading to high burnout.



Engineering-era CyberAI Engineer

- **Agent Auditor:** Instead of reviewing alerts, they audit the machine that audits alerts, maintaining confidence scores and flagging behavioral anomalies to escalate to engineering.
- **Deterministic Oversight:** Investigation uses formal guardrails to ensure the agent operates within defined logic boundaries.
- **Orchestration:** Response logic is codified into auditable, machine-speed workflows the human validates the outcome.
- **Engineering Focus:** Focus on diagnostic accuracy in investigating AI model drift, context window pollution, or prompt injection, shifting from vocational output to system integrity.

Conclusions

- **The cybersecurity craft model has already broken.** Adversary breakout times of 29 minutes and 3,000 alerts per day have structurally exceeded the processing capacity of human intuition. This is not a resourcing problem. It is a mathematical one.
- **The transition from craft to engineering science is already underway.** Augmented SOC, CTEM, and continuous compliance assurance are not future concepts. They are present-day engineering responses to the failure of craft-era security operations, each requiring clean data, codified logic, and defined guardrails.
- **The human role must evolve, not disappear.** The science of cybersecurity requires the analyst to move from working IN the system to working ON the system; auditing the machine, validating the axioms, and ensuring the science remains ethically accountable to the people it protects.

References

Brundage, M. et al. (2018) *The Malicious Use of Artificial Intelligence: Forecasting, Prevention, and Mitigation*. Oxford: Future of Humanity Institute. Available at: arxiv.org/abs/1802.07228 (Accessed: 17 April 2026).

CrowdStrike (2026) *2026 Global Threat Report: Year of the Evasive Adversary*. Austin, TX: CrowdStrike, Inc. Available at: crowdstrike.com (Accessed: 19 April 2026).

NIST (2023) *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. Gaithersburg, MD: National Institute of Standards and Technology.

NIST (2024) *Cybersecurity Framework (CSF) 2.0*. Gaithersburg, MD: National Institute of Standards and Technology.

Ponemon Institute (2023) *2023 SOC Performance Report*. Traverse City, MI: Ponemon Institute. Available at: ponemon.org (Accessed: 17 April 2026).

SANS Institute (2025) *SANS SOC Survey 2025* [Crowley, C.]. Available at: sans.org (Accessed: 19 April 2026).

Seacord, R. C. (2013) *Secure Coding in C and C++*. 2nd edn. Upper Saddle River, NJ: Addison-Wesley.

Simon, H. A. (1996) *The Sciences of the Artificial*. 3rd edn. Cambridge, MA: MIT Press.

Vectra AI (2026) *2026 State of Threat Detection and Response: Cyber Resilience in the AI Era*. Available at: vectra.ai (Accessed: 19 April 2026).

Walton, D. J. (2024) *Culturally Responsive Computing: An Introduction into Computer Science, Security, and Technology*. Boston, MA: ROTEL.

Wootton, D. (2015) *The Invention of Science: A New History of the Scientific Revolution*. New York: HarperCollins.

--

Claude (Anthropic, 2025) was used to assist with editing, reference formatting, and structural feedback, during the preparation of this submission. All academic arguments, citations, and conclusions are the author's own.